Technische Hochschule Ingolstadt

Klausur „**Security Engineering in der IT**“
Sommersemester 2024

Studiengang:	Master Cloud Applications und Security Engineering (CASE)
Dozent:	Prof. Dr.-Ing. Hans-Joachim Hof
Datum	19.07.2024
Matrikel-Nr.:	
Raum-Nr.:	D114
Platzziffer:	

Bearbeitungszeit: 90 Minuten

Umfang: 5 Aufgaben auf 10 durchnummerierten Blättern einschließlich Deckblatt

Zugelassene Hilfsmittel: keine

Weitere Hinweise:
- Antworten Sie kurz und präzise. Falsche Antworten oder unpräzise Antworten können zu Punktabzug führen.
- Bei Platzmangel benutzen Sie bitte die Rückseite des vorhergehenden Blattes. Der verfügbare Platz reicht bei normaler Schriftgröße für eine korrekte Lösung aus.

Tipp: lesen Sie die Aufgaben erst komplett durch, bevor Sie mit der Bearbeitung beginnen

Bewertung (wird vom Prüfer ausgefüllt):

	1	2	3	4	5	Summe	Note
Punkte							
Zweit-korrektur							

Aufgabe 1: Kryptographie (20 Punkte)

a) Es sind folgende Szenarien gegeben:

Szenario 1: Ein dezentrales Chat-System (d.h. ohne zentralen Server) ermöglicht den Austausch von Ende-zu-Ende verschlüsselten Nachrichten.

Szenario 2: Eine Datei wird mit Hilfe eines Passworts verschlüsselt werden.

Szenario 3: Eine Festplatte wird komplett verschlüsselt

Szenario 4: Über digitalen Rundfunk (Broadcast) wird ein verschlüsseltes TV-Signal versendet, welches durch Decoder-Boxen dekodiert wird, so dass eine Anzeige nur für zahlende Kunden möglich ist.

Wählen Sie durch Ankreuzen in der Tabelle für die einzelnen Szenarien, ob sich ein symmetrisches Verfahren (sym) oder ein asymmetrisches Verfahren (asym) besser eignet. Begründen Sie Ihre Entscheidung:

Szenario Nr.	Asym	Sym	Begründung
1			
2			
3			
4			

b) Skizzieren Sie grafisch die Verschlüsselung im CCM Modus. Sie dürfen die Verschlüsselungsfunktion als einen Block darstellen.

c) Begründen Sie anhand eines konkreten, praktischen Beispiels, warum es wichtig ist, Kerkhoffs Prinzip einzuhalten.

Aufgabe 2: Bedrohungs- und Risikoanalyse (19 Punkte)

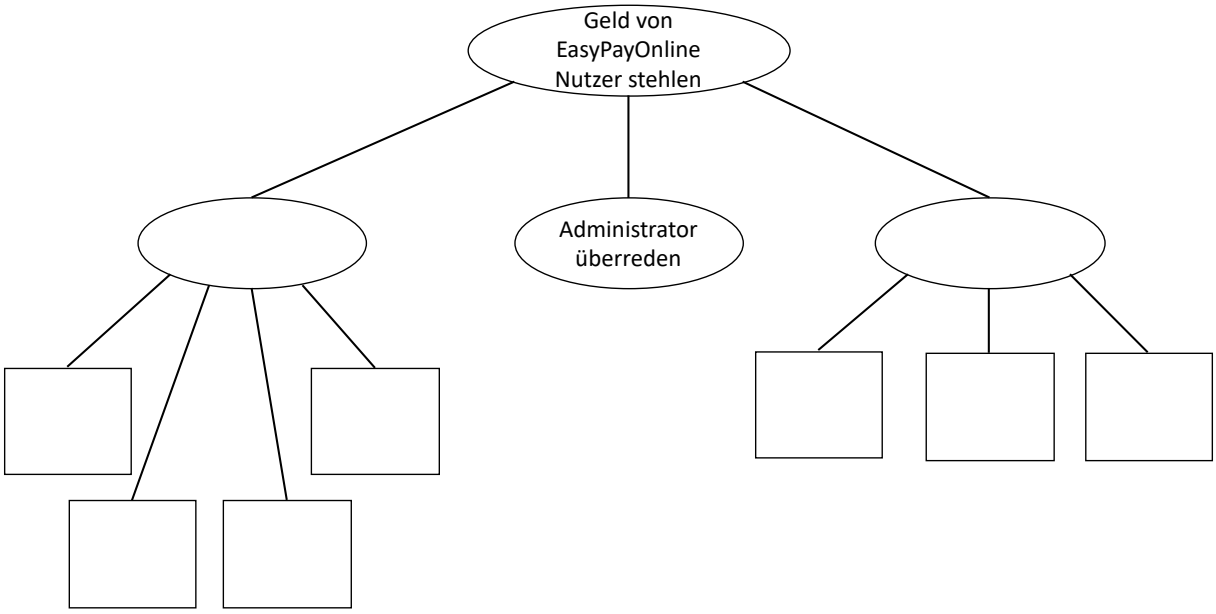
Sie erstellen das EasyPayOnline Zahlungssystem. Das Zahlungssystem besteht aus einer App (eApp) und einem Server (eServer). Der eServer verwaltet alle Guthaben der Nutzer und weist jedem Benutzer bei der erstmaligen Registrierung eine eindeutige ID (eID) zu.

Die eApp verfügt über folgende Funktionen:

- Anzeige des aktuellen Kontostands
- Überweisung an einen anderen EasyPayOnline Nutzer durch Angabe des zu überweisenden Betrags sowie der eID des Empfängers.

a) Sie führen eine Bedrohungs- und Risikoanalyse durch. Welches ist Ihrer Meinung nach **der wichtigste** Wert in EasyPayOnline?

b) Ergänzen Sie den angegebenen Angriffsbaum. Fügen Sie nur Text in die bestehenden Formen ein.



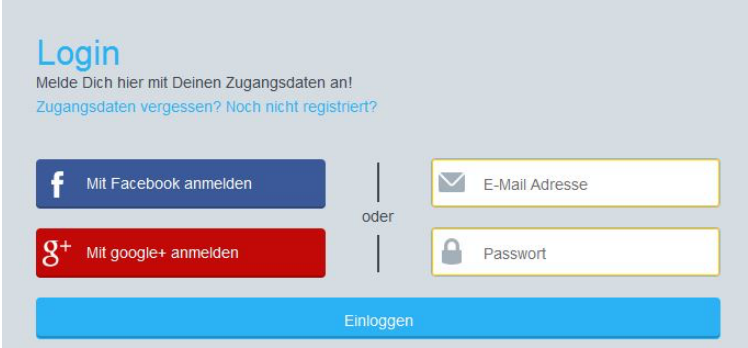
c) Im Rahmen des OWASP Risk-Rating stellt sich heraus, dass alle im Angriffsbaum identifizierten Angriffe ein hohes oder kritisches Risiko für den Wert aus Aufgabenteil a) darstellen. Nennen Sie zwei Sicherheitsanforderungen an EasyPayOnline, die möglichst vielen Angriffen begegnen

d) Schlagen Sie pro Sicherheitsanforderung aus Aufgabenteil c) eine **wirksame technische Schutzmaßnahme** für EasyPayOnline zur Erfüllung der Sicherheitsanforderung vor.

Aufgabe 3: Sicherheitsprinzipien (17 Punkte)

a) Die Firma ACME schützt ihr internes Netzwerk durch eine sehr leistungsfähige Firewall am Übergang zwischen dem Internet und dem internen Netzwerk. Die Verantwortlichen sind der Meinung, dass ACME damit ausreichend geschützt ist. Nehmen Sie Stellung zu dieser Aussage unter Berücksichtigung der in der Vorlesung behandelten Sicherheitsprinzipien.

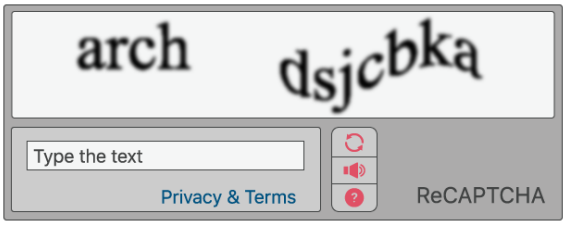
b) Die Firma ACME möchte die User Experience für den Zugriff auf unternehmensinterne Dienste verbessern und ermöglicht es den Mitarbeitern deswegen, sich mit Facebook oder mit Google+ anzumelden (siehe Bild). Die Dienste verarbeiten sowohl personenbezogene als auch vertrauliche Daten.



Welches Sicherheitsprinzip wird hier verletzt? Begründen Sie.

c) Der CEO des Unternehmens ACME fordert seinen CIO auf, die IT-Sicherheit der Marketing-Abteilung nicht weiter zu betrachten und sich auf die Sicherheit der Forschungs-Abteilung zu konzentrieren. Nehmen Sie Stellung zu diesem Vorgang unter Berücksichtigung der in der Vorlesung vorgestellten Sicherheitsprinzipien.

d) Eine Webanwendung verwendet als Security-Mechanismus ein Captcha wie in der folgenden Abbildung zu sehen:



Jedes Mal, wenn der Benutzer eine Aktion durchführt, muss er das Captcha lösen. So soll verhindert werden, dass die Aktion durch ein Skript ausgeführt wird.

Welche Guidelines aus dem Design Guide für benutzbare Sicherheitsverfahren verletzt das Captcha? Begründen Sie kurz.

Aufgabe 4: Sicherheitsmodellierung (19 Punkte)

a) Sie verwenden UML zur Modellierung eines Systems. Sie haben eine Klasse „Benutzer“ mit den Attributen Vorname, Name und Adresse sowie IBAN und Login-Passwort. Als Sicherheitsanforderungen liegt fest, dass personenbezogene Daten vertraulich gehalten werden, Passwörter und Zahlungsdaten (IBAN) vertraulich und integer sein müssen und die Zahlungsdaten darüber hinaus auch eine hohe Verfügbarkeit haben sollen. Zeigen Sie, wie sie diese Sicherheitsanforderungen für die Klasse Benutzer in UMLsec darstellen.

b) Die Klasse „Benutzer“ befindet sich in der Komponente „Webshop“. Die Klasse „Benutzer“ bietet eine Funktion getIBAN() an, welche die IBAN eines Kunden zurückgibt. Diese Methode wird von einer Klasse „Abrechnung“ aus der Komponente „Zahlungssystem“ aufgerufen. Die beiden Komponenten befinden sich im gleichen Netzwerk. Stellen Sie dieses Szenario in UMLsec so dar, dass die Sicherheitsziele aus a) formuliert sind.

c) Wie geschieht in UMLsec die Verbindung mit einem Angreifermodell? Erklären Sie an dem Beispiel aus a) und b).

d) Würden Sie Modifikationen am Standardangreifermodell von UMLsec vorschlagen? Begründen Sie Ihre Antwort.

Aufgabe 5: Security-Testing (15 Punkte)

In einer App sind die unten genannten Fehler a)-e) vorhanden – geben Sie in der Tabelle unten jeweils an, welche Testtechnik **am besten** geeignet ist, um den jeweiligen Fehler zu finden. Begründen Sie Ihre Antwort

a) Die Anwendung schützt die Kommunikation zwischen App und Server, indem sich der Server durch ein Zertifikat ausweist. Das verwendete Zertifikat wurde von der öffentlichen Zertifizierungsstellen Verisign unterschrieben. Durch einen Programmierfehler akzeptiert die Anwendung nicht nur Zertifikate des eigenen Servers, sondern alle Zertifikate, die von Verisign unterschrieben wurden, also auch Zertifikate, die sich Privatpersonen besorgen können.

b) Durch einen Programmierfehler in der App kann ein Pufferüberlauf (Buffer Overflow) ausgelöst werden.

c) Die App hat umfangreiche Maßnahmen zum Schutz von personenbezogenen Daten getroffen, jedoch werden in der App überhaupt keine personenbezogenen Daten verarbeitet.

d) Die App wurde im Auftrag eines Kunden entwickelt, der explizit eine Passworteingabe vor jedem Zugriff auf die App gefordert hat – diese Funktionalität wurde schlicht und einfach vergessen zu implementieren.

e) Die App öffnen einen Wartungszugang: wenn sich ein Smartphone mit der App in einem WLAN befindet, dann öffnet die App auf Port 2020 einen Webserver. Über diesen Webserver kann die Anwendung ferngesteuert werden, eine Authentifizierung ist für diese Funktion nicht implementiert.

Fehler	**<u>Beste</u> Testtechnik zur Entdeckung**	**Begründung für Testtechnik**
a)		
b)		
c)		
d)		
e)		